

Moq under fire for endangering data privacy by including SponsorLink



The widely used open source project Moq is embroiled in controversy after it was revealed that its latest release included a dependency known as SponsorLink. Moq, pronounced ‘Mock’, is a prominent player in the open source software ecosystem, boasting over 476 million lifetime downloads and a staggering 100,000 daily downloads from the NuGet software registry. The criticism erupted when Moq’s 4.20.0 release quietly incorporated the SponsorLink project, prompting backlash from open source software enthusiasts who felt betrayed by what they deemed a breach of trust.

The root of the criticism lies in SponsorLink’s deceptive nature—it is shipped on NuGet as closed source software, containing obfuscated DLLs (dynamic link libraries) that surreptitiously gather hashed email addresses of users and transmit them to SponsorLink’s content delivery network (CDN). A prominent software developer, Georg Dengl, expressed his concerns, stating, “This is a closed-source project, provided as a DLL with obfuscated code, which seems to at least scan local data (git config?) and sends the hashed email of the current developer to a cloud service.” This scanning capability is integrated into the .NET analyser tool during the build process, raising significant privacy concerns.

Mike (@d0pare), a GitHub user, decompiled the DLLs and shared a reconstructed version of the source code, revealing that SponsorLink leverages external git processes to obtain email addresses and then computes SHA-256 hashes of these addresses, which are subsequently sent to SponsorLink’s CDN. The inclusion of such telemetry code within Moq and SponsorLink has raised questions about privacy and transparency within the open source community. Concerns have also been raised about the ethics of distributing a closed source dependency via open source channels, potentially compromising user data privacy.

In response to the backlash, Daniel Cazzulino, Moq’s owner, updated SponsorLink’s README with a detailed ‘Privacy Considerations’ section, asserting that only hashed email addresses were collected and that the actual

Open source propels software strategy at Porsche

Luxury car maker Porsche has ventured further into the realm of open source software. Porsche’s recently published guide, titled ‘FOSS Movement’, articulates the brand’s growing emphasis on leveraging free and open source software (FOSS) within its software strategy. Roughly two years after the inception of its open source initiative, the company is now making strides by sharing its fundamental principles through this publication.

The document elucidates the core values underpinning free and open source software and outlines the roles that employees, spanning departments such as vehicle development, corporate IT, legal, and Porsche Digital, play in collaborating with these technologies. There is a commitment to uniformly embed open source practices across Porsche’s operations. This integrated approach not only enhances internal cohesion but also fosters external collaboration with open source communities on a global scale.

The influence of open source permeates Porsche’s digital transformation, underpinning crucial aspects of its software ecosystem. From the intricate control units within vehicles to pivotal elements like the ‘My Porsche’ digital platform and the ‘Porsche Design System’, the power of open source is evident.

Porsche’s collaboration with open source projects also serves as a conduit for discovering and nurturing fresh talent. This engagement allows the company to interact closely with a global cadre of technological leaders, fostering an environment of cross-pollination and shared expertise.